



CYBERFORT
RESILIENT EUROPE

CYBERFORT CRA readiness assessment of SEUXDR

CLONE SYSTEMS PILOT
31 JULY 2026 · LARNAKA, CYPRUS

Georgios Koutidis
Clone Systems CY, LTD.

WHAT CYBERFORT RAN, END TO END



CYBERFORT
RESILIENT EUROPE

Scope & register

- CRA Scope Assessment wizard
- Register SEUXDR with Criticality, CRA Vertical Profile, Economic Operator
- Seed the CRA framework and its pre-built risk / control / policy chain

Discover & evidence

- SBOM Generator (Syft) — the product's first ever SBOM
- Dependency Check (OSV) on go.mod and package-lock.json
- Code Analysis (Semgrep) on the real Go and TypeScript source
- Triage in Scan Findings → Link to Risk; publish CycloneDX VEX

Assess & document

- Six CRA Technical File areas
- 52-question conformity assessment, evidence on every answer
- Compliance status for all 30 objectives
- Evidence Library with integrity verification

Declare & plan

- Gap analysis + compliance chain map
- EU Declaration of Conformity readiness score
- CE Marking Checklist
- Seven-document readiness pack + ranked remediation backlog



This Project has received funding from the Digital Europe Programme under Grant Agreement No: 101190281



**Co-funded by
the European Union**



ECCC
EUROPEAN CYBERSECURITY
COMPETENCE CENTRE

FALL UNDER CRA SCOPE



CYBERFORT
RESILIENT EUROPE

ANNEX III • Important product with digital elements • CLASS I

The classification is over-determined — three independent Annex III limbs apply:

SIEM system

Bundles Wazuh 4.11 inside its own image. Centralised multi-tenant event collection, storage and query; MITRE ATT&CK enrichment and STIX 2.1 export.

Intrusion detection and prevention

Self-declared HIDS. Prevention is implemented, not just detection — BLOCK_IP installs firewall DROP rules on the endpoint.

Removes or quarantines malicious software

Malware-triggered DELETE_FILE executes on the endpoint as root, dispatched from the manager.

Consequence — Article 32(2)

A Module A internal-control self-declaration is not a legal option for this product. We must engage a notified body, or apply harmonised standards in full once they exist. Every downstream compliance decision has to be built around that — and it is the single most consequential output of the whole pilot.



This Project has received funding from the Digital Europe Programme under Grant Agreement No: 101190281



Co-funded by
the European Union



ECCC
EUROPEAN CYBERSECURITY
COMPETENCE CENTRE

THE PRODUCT UNDER ASSESSMENT



CYBERFORT
RESILIENT EUROPE

Product	SEUXDR — self-hosted SIEM/XDR with AI-driven remediation
Release	main @ 00a95ad · agent 1.0.1 · registered as asset SEUXDR v3.4
Stack	Go 1.23 manager + agent · React 19 front end · Wazuh 4.11 + OpenSearch detection · Ollama phi4:14b for analysis
Endpoints	Windows (Event Log) · Linux (journald) · macOS (Unified Logging)
Remediation	BLOCK_IP · KILL_PROCESS · DELETE_FILE — executed on the host
Differentiator	the LLM runs in-network; customer telemetry never reaches a third-party cloud model

As-built architecture

Endpoint agents

Windows · Linux · macOS



Manager · :8081 mTLS enrolment · :8443 TLS API + WebSocket

Wazuh 4.11 · OpenSearch · SQLite



Ollama · :11434

phi4:14b, local inference only

Front end :8080 — unreachable as shipped: no /api/login route exists



This Project has received funding from the Digital Europe Programme under Grant Agreement No: 101190281



Co-funded by
the European Union



ECCC
EUROPEAN CYBERSECURITY
COMPETENCE CENTRE

SPECIFY CRA OBJECTIVES



CYBERFORT
RESILIENT EUROPE

Chapter		Objectives
Chapter I	General provisions — scope, Art. 6 + Annex I	2
Chapter II	Obligations of economic operators — Art. 13, 14, 25, 26	4
Chapter III	Conformity of the product	1
Chapter V	Market surveillance — Art. 52, 54, 70	2
ANNEX I	Essential requirements — objectives 1, 2, 3a–3k	13
Vuln. Handling	Part II obligations — objectives 1–8	8

30 objectives in the asset scope · 52 conformity questions · each objective carries seeded policy templates, an evidence upload and a compliance status.

Subchapter	Objective Title	Requirement Description	Objective Utilities	Policies	Evidence	Compliance S
Internal Security Processes and Controls	Article 25 (Security Measures)	Manufacturers must put in place appropriate and proportionate internal processes and measures to ensure compliance with the CRA.	Information Security Policy, Product Cybersecurity Policy, Management Review Minutes, Information Security Objectives & Plan, Confidentiality Policy, Physical Security Policy, Secure Code Policy, Encryption Policy, Risk Assessment Methodology, Management Review Minutes, Physical Security Policy, Risk Assessment Methodology	- Risk Management Policy - Software Development Lifecycle Policy - Information Security Policy - Information Security Objectives And Plan - Product Cybersecurity Policy - Encryption Policy - Risk Assessment Methodology - Management Review Minutes - Physical Security Policy - Confidentiality Policy	- Approved - Approved - Approved - Draft - Draft - Review - Draft - Draft - Draft - Approved	- Upload - in review
Manufacturer Obligations and Responsibilities	Article 13 (Obligations of Manufacturers)	Manufacturers have comprehensive obligations, including ensuring products meet essential requirements, drawing up technical documentation, conducting conformity	Information Security Policy, Organizational Roles, Responsibilities And Authorities, Product Registry Form, Vulnerability Management Policy, Incident Management Policy, Incident Management Policy, Product Registry Form	- Incident Management Policy - Information Security Policy - Vulnerability Management Policy - Organizational Roles Responsibilities And Authorities - Product Registry Form	- Draft - Approved - Approved - Draft - Draft	- Upload - in review

Annex I objectives 3a–3k for SEUXDR, with linked policies and evidence state



This Project has received funding from the Digital Europe Programme under Grant Agreement No: 101190281



Co-funded by
the European Union



STEP 1 · SEED THE FRAMEWORK



CYBERFORT
RESILIENT EUROPE

One dropdown, one checkbox

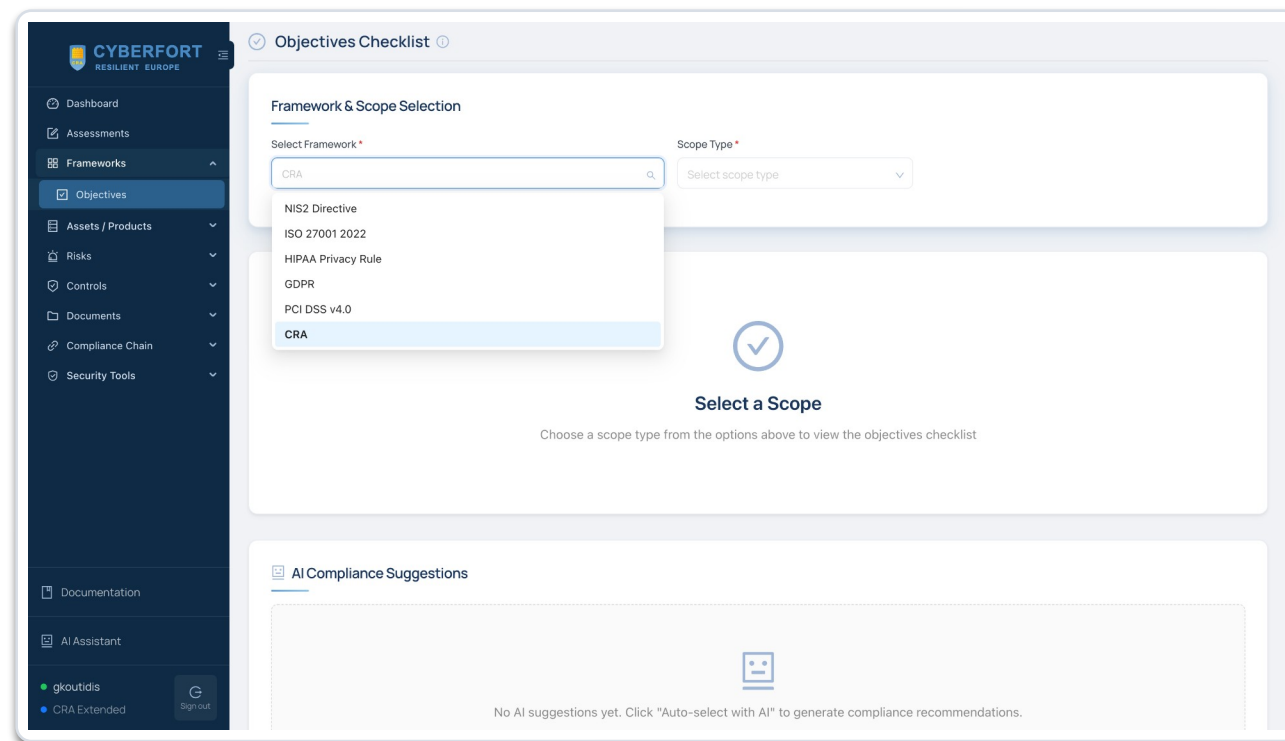
Pick CRA from the framework template list, leave “Include pre-built chain links” enabled, click Add Selected Framework. That single action seeds the objective tree and the entire connected library.

What it creates for you

For the CRA framework the tenant now links 45 risks, 98 controls, 48 policies and 330 objective links across 9 assets. Controls arrive as Baseline Controls and CRA Horizontal Controls (codes like CRA-SD-1, CRA-VH-1); policies arrive as Draft with their body text already written.

Why it matters

Nothing after this step was written from a blank page. The rest of the pilot is reviewing and evidencing seeded entities rather than authoring them — the difference between a compliance programme you can start today and one you start next quarter.



Frameworks → Objectives — selecting CRA from the six frameworks seeded in the tenant



This Project has received funding from the Digital Europe Programme under Grant Agreement No: 101190281



Co-funded by
the European Union



ECCE
EUROPEAN CYBERSECURITY
COMPETENCE CENTRE

STEP 2 · REGISTER THE PRODUCT



CYBERFORT
RESILIENT EUROPE

Criticality

The verbatim option “Security information and event management (SIEM) systems”, under the ANNEX III – Class I group header. It drives the Technical File pages, the CE checklist and the DoC score. Leave it blank and every CRA module stays inert.

CRA Vertical Profile

“Anti-Malware / Malware Detection Product” — the second Annex III limb, recorded so the classification argument is visible in the asset record itself rather than buried in a report.

Economic Operator

Manufacturer. It determines which obligations apply: Articles 13, 14, 25 and 26 rather than the importer or distributor set.

Justification

Free text, and worth writing properly — it is the first thing an assessor reads when asking why you chose Class I over Class II.

Add New Asset — the CRA fields appear only when CRA mode is on for the tenant



This Project has received funding from the Digital Europe Programme under Grant Agreement No: 101190281



Co-funded by
the European Union



ECCC
EUROPEAN CYBERSECURITY
COMPETENCE CENTRE

STEP 3 · GENERATE THE SBOM



CYBERFORT
RESILIENT EUROPE

The finding

SEUXDR shipped no SBOM. The closest artefact was a hand-maintained 26-entry licence list that still held its template placeholder and omitted almost every indirect dependency.

Why it blocks a DoC

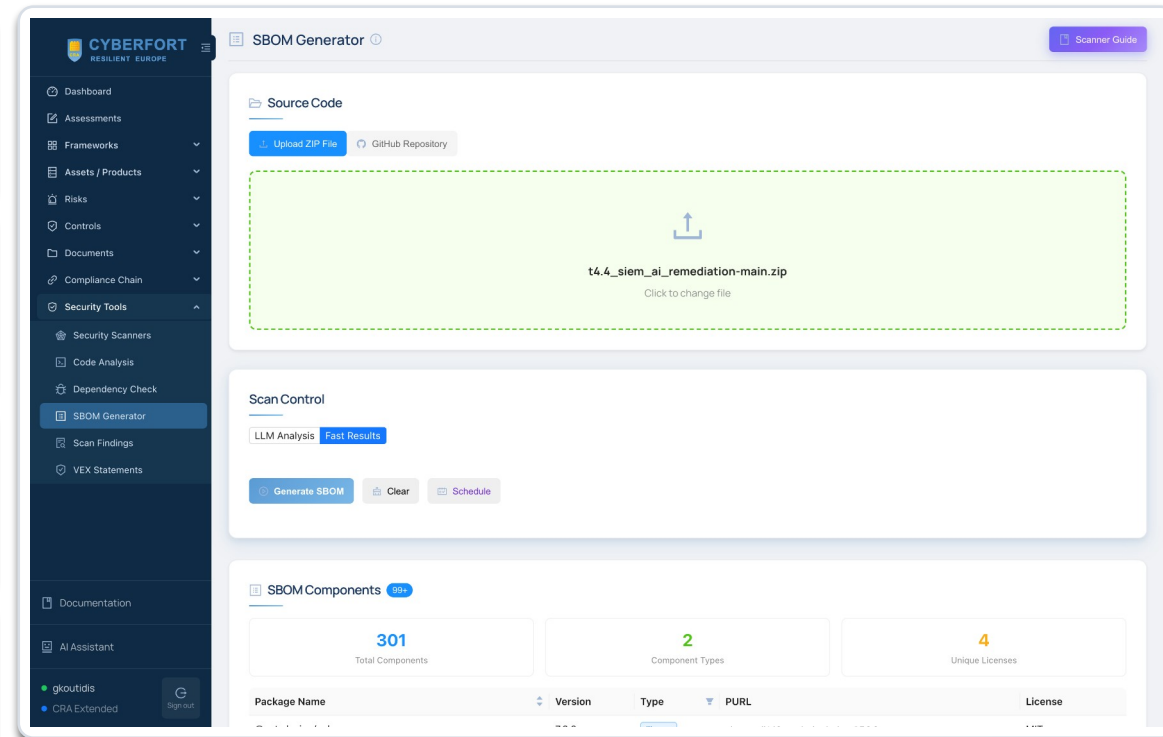
Annex I Part II(1) requires a component inventory covering at least top-level dependencies, in a commonly used machine-readable format. It is the hard blocker behind questions 38, 39 and 40.

What the run produced

301 components, 298 libraries and 3 files, across 4 licences — BSD-3-Clause, MIT, Unlicense and ISC — in 23.26 seconds from the repository archive. It also surfaced the sabotaged faker package sitting in production dependencies.

What we did next

CI now regenerates CycloneDX SBOMs on every build and attaches them to releases; SBOM_POLICY.md commits to cadence, version tracking and delivery.



The real run: 301 components across 4 licences, generated in 23 seconds



This Project has received funding from the Digital Europe Programme under Grant Agreement No: 101190281



Co-funded by
the European Union



ECCC
EUROPEAN CYBERSECURITY
COMPETENCE CENTRE

STEP 4 · SCAN THE REAL CODEBASE



CYBERFORT
RESILIENT EUROPE

What we scanned

github.com/CyberGuardEU/t4.4_siem_ai_remediation at commit 00a95ad. The private-repository route needs a GitHub token, so the run used the source archive of that exact commit.

OSV — dependency findings

golang-migrate v3.5.4+incompatible, from 2018 when upstream is v4.
gorilla/websocket v1.4.2, from 2020 — and it carries the remediation command channel.

Semgrep — code findings

Critical: a live admin credential committed in three tracked files. High: no authentication on any API route; private keys written 0644; enrolment secrets logged in cleartext.

The compounding factor

No dependency scanning existed in the repository at all, so there was no mechanism to learn that any of this was true.

Timestamp	Target	Scan Type	Status	Severity	Duration (s)	User	Organization	Actions
> Jul 30, 2026, 02:40:10 PM	vulner...	basic	FAILED	N/A	0.00	manastasiadis@clone-s...	Clone Systems	
> Jul 30, 2026, 02:40:10 PM	vulner...	basic	FAILED	N/A	0.00	manastasiadis@clone-s...	Clone Systems	
> Jul 30, 2026, 01:49:30 PM	t4.4_si...	dependency... scan	COMPLETED	N/A	34.15	gkoutidis@clone-syste...	Clone Systems	
> Jul 30, 2026, 01:40:10 PM	vulner...	basic	FAILED	N/A	0.00	manastasiadis@clone-s...	Clone Systems	
> Jul 30, 2026, 01:40:10 PM	vulner...	basic	FAILED	N/A	0.00	manastasiadis@clone-s...	Clone Systems	
> Jul 30, 2026, 12:40:10 PM	vulner...	basic	FAILED	N/A	0.00	manastasiadis@clone-s...	Clone Systems	
> Jul 30, 2026, 12:40:10 PM	vulner...	basic	FAILED	N/A	0.00	manastasiadis@clone-s...	Clone Systems	
> Jul 30, 2026, 11:40:10 AM	vulner...	basic	FAILED	N/A	0.00	manastasiadis@clone-s...	Clone Systems	

Scan Results after the run — dependency_scan COMPLETED against the product, 34.15 s



This Project has received funding from the Digital Europe Programme under Grant Agreement No: 101190281



Co-funded by
the European Union

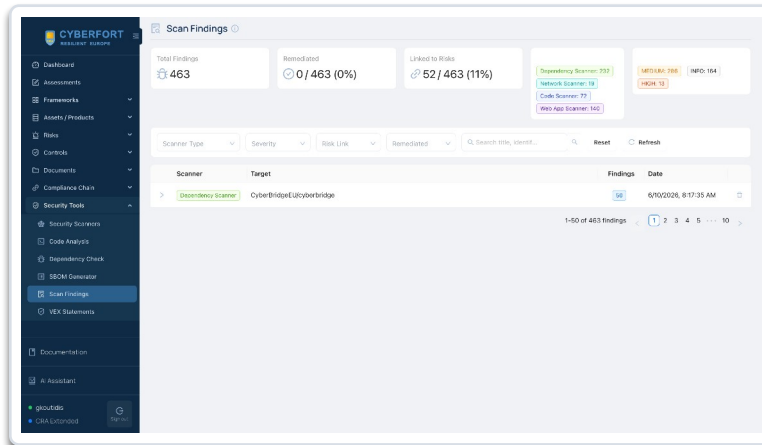


ECCC
EUROPEAN CYBERSECURITY
COMPETENCE CENTRE

STEP 5 · FINDINGS → RISKS & RISKS → VEX

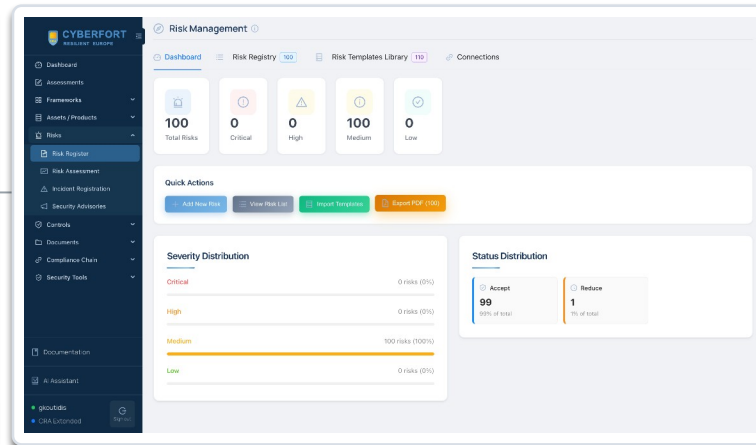


Scan output on its own is an incident report. The chain below is what turns it into technical documentation — and every hop is a click, not a hand-off.



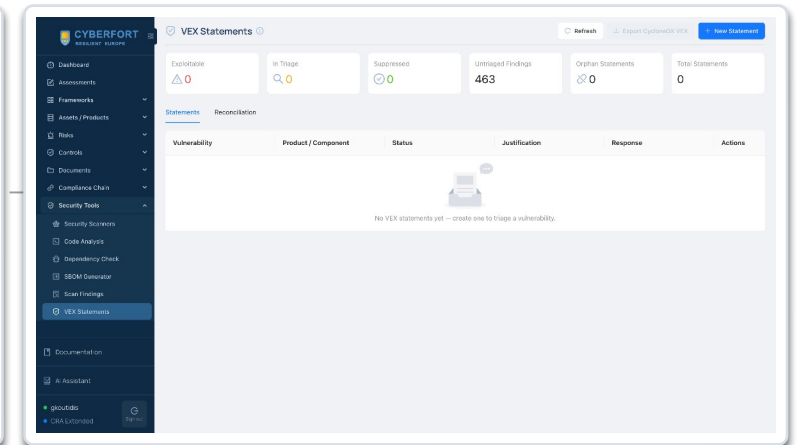
Scan Findings

One filterable table across ZAP, Nmap, Semgrep and OSV, with severity counts, a remediation toggle and a Link to Risk action per finding. Link to Risk is what feeds the Compliance Chain — an unlinked finding is invisible to the gap analysis.



Risk Register

Five blocking risks filed against SEUXDR, each linked from its finding and scored for likelihood, severity and residual risk.



VEX Statements

CycloneDX VEX — how you tell downstream users that a CVE in your SBOM is not exploitable in your product.



This Project has received funding from the Digital Europe Programme under Grant Agreement No: 101190281



Co-funded by
the European Union



STEP 6 · POPULATE THE CRA TECHNICAL FILE



CYBERFORT
RESILIENT EUROPE

Six pages, six specifications

SBOM Management · Secure SDLC Evidence · Security Design · Patch & Support Policy · Vulnerability Disclosure · Dependency Policy. Each lists the numbered requirements the CRA expects you to document and cites the Article or Recital behind them.

Where SEUXDR stood

One of the six had an artefact after Step 3 — the SBOM. The other five had no corresponding documentation at all: no threat model, no CI security gates, no declared support period, no disclosure policy, no dependency governance.

Why the pages earn their keep

They are a specification for the writing you owe, in the regulator's own order. Paired with the seeded policy templates from Step 2, adopting a policy takes minutes instead of a week of drafting.

Vulnerability Disclosure — one of six pages, and the one that cites the Article 14 ENISA duty



This Project has received funding from the Digital Europe Programme under Grant Agreement No: 101190281



Co-funded by
the European Union



ECCC
EUROPEAN CYBERSECURITY
COMPETENCE CENTRE

STEP 7 · THE 52-QUESTION CONFORMITY ASSESSMENT



CYBERFORT
RESILIENT EUROPE

How it works

52 mandatory questions, paginated ten per page. Yes / No / Partially / N/A, an Assign Policy selector, an Evidence Description and Attach File(s). The Completed flag flips only once a valid answer is saved.

The result

2 Yes · 19 Partially · 31 No. Q29 (availability after an incident) and Q34 (security-relevant information recording) are honest Yes answers backed by code — claim them, with evidence. Never answer “Partially” where the evidence supports only “No” — the score is not a grade, it is the input to a remediation plan.

Suggest from Scans / AI Suggest Answers

Both toolbar actions pre-populate answers from the scanner output filed in steps 3–5. Used on Q13, Q38 and Q39 the OSV and SBOM results feed them directly.

The screenshot displays the CYBERFORT assessment interface. On the left is a dark sidebar with a menu containing: Dashboard, Assessments (highlighted), Frameworks, Assets / Products, Risks, Controls, Documents, Compliance Chain, and Security Tools. Below the menu are links for Documentation and AI Assistant, and a user profile section for 'gkoutidis' with a 'Sign out' button. The main area shows three questions. Each question has a status bar (Mandatory: YES, Completed: NO, Common in: CRA(clone-systems.com)), a question text, radio button options (Yes, No, Partially, N/A), an 'Assign Policy' dropdown (set to 'No Policy'), an 'Evidence Description' text area, and an 'Attach File(s)' section. Action buttons for 'Save Answer', 'Clear Answer', and 'Attach File(s)' are on the right of each question. The bottom of the interface shows a 'Sign out' button and a 'G' icon.

Each question carries an answer, a policy assignment, an evidence description and attachments



This Project has received funding from the Digital Europe Programme under Grant Agreement No: 101190281



Co-funded by
the European Union



ECCC
EUROPEAN CYBERSECURITY
COMPETENCE CENTRE

PILOT BASELINE : 7% CRA READY



CYBERFORT
RESILIENT EUROPE

7%

Not Yet Ready

60% objectives + 40% assessment.
Tenant-aggregated: 30 of 270 compliant.

CRA objectives

of 30



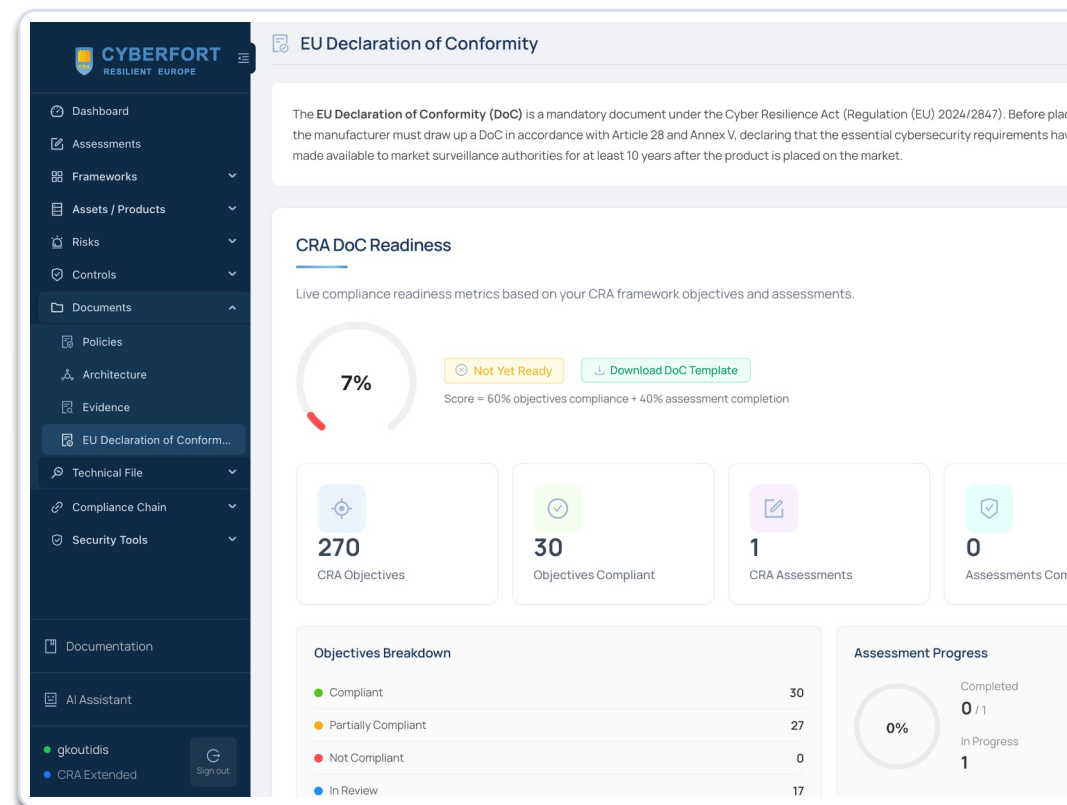
Conformity answers

of 52



A complete assessment showing 7% is where improvement starts.

- It is not a failure of the assessment — it is the assessment working.
- The score is live: it moves as objectives are evidenced and answers change.
- Scoped to SEUXDR: 2 of 30 CRA objectives compliant — recorded in the platform, not estimated.
- Learning this from our own platform, before a notified body or a market-surveillance authority does, is the outcome CYBERFORT exists to produce.
- Two further gaps surface here: no notified body engaged, and no single product version to declare — agent 1.0.1, front end 0.0.0, manager unversioned.



This Project has received funding from the Digital Europe Programme under Grant Agreement No: 101190281



Co-funded by
the European Union



ECCC
EUROPEAN CYBERSECURITY
COMPETENCE CENTRE

WHAT WE CLAIM



CYBERFORT
RESILIENT EUROPE

Modern authenticated encryption throughout

AES-GCM with random per-message nonces; RSA-OAEP-SHA256 key wrapping; per-agent key isolation. A repository-wide review found no ECB, no unauthenticated CBC and no static IV.

Annex I 3c · 3d → Q24, Q25

Availability and resilience — answered Yes

Failed-alert queue with exponential backoff, a dead-letter queue for analyst review, and resume-after-restart state tracking. The best-engineered subsystem in the product.

Annex I 3f → Q29, Q30

Security-event recording — answered Yes

Structured JSON logging with request correlation IDs, plus a fully persisted AI reasoning trail including react_history. Explainability better than typical for this product class.

Annex I 3j → Q34, Q35

Structural blast-radius limitation

Remediation is strictly per-agent: no fleet-wide action primitive exists anywhere in the codebase, so one bad AI decision cannot cascade. Structural, not configurational.

Annex I 3g · 3i → Q31, Q33



This Project has received funding from the Digital Europe Programme under Grant Agreement No: 101190281



Co-funded by
the European Union



ECCC
EUROPEAN CYBERSECURITY
COMPETENCE CENTRE

WHAT BLOCKS MARKET PLACEMENT



CYBERFORT
RESILIENT EUROPE

01

No user authentication, authorisation or accountability

The shipped build has no auth middleware, no login route and no user/role/session schema — removed deliberately on 29 Oct 2025. All 22 API routes are open, including installer download.

Annex I 3b · Q20, Q21, Q22

02

Unauthenticated remote destructive action across the fleet

The remediation endpoint validates the action verb and nothing else before deleting files, killing processes or blocking IPs as root — unrate-limited, unattributed, and it bypasses the manual_only safety mode entirely.

Annex I 3b · 2 · 3d · Q13, Q20, Q26

03

Unvalidated LLM output becomes a root-privileged command argument

The only check on an AI-chosen target is that it is non-empty. No IP validation, no path canonicalisation, no protected-path denylist. Prompt injection from attacker-controlled log text is unmitigated.

Annex I 1 · 3d · 3i · Q12, Q25, Q33

04

The entire Annex I Part II apparatus is absent

No SBOM, no SECURITY.md or security contact, no coordinated disclosure policy, no CI, no dependency scanning, no code signing, no changelog — and no git tags at all.

VH-1 ... VH-8 · Q38–Q48



This Project has received funding from the Digital Europe Programme under Grant Agreement No: 101190281



Co-funded by
the European Union



ECCC
EUROPEAN CYBERSECURITY
COMPETENCE CENTRE

REMEDiation STEP I



CYBERFORT
RESILIENT EUROPE

Published a way to report a vulnerability to us

A monitored security contact, acknowledgement within three working days, triage within ten, and remediation windows set by severity. Coordinated disclosure with a 90-day default embargo and public credit for reporters. Before this the readme said "contact []".

Wired the regulator's clock into the process

Article 14 is not advisory: an actively exploited vulnerability means an early warning to ENISA and the national CSIRT within 24 hours, a full notification within 72, and a final report within 14 days. That runbook now exists, with named roles and an evidence pack.

Made the component inventory automatic

CycloneDX SBOMs are generated for the Go module and the front end on every build and attached to every release. govulncheck, npm audit, Trivy and gitleaks run on push and weekly. Dependabot covers Go, npm, Docker and the actions themselves.

Objectives moved

- ✓ VH-1 components and SBOM
- ✓ VH-2 remediate without delay
- ✓ VH-3 regular testing
- ✓ VH-4 public disclosure
- ✓ VH-5 disclosure policy
- ✓ VH-6 contact address
- ✓ VH-8 update dissemination

Why it counts

Six of the eight Vulnerability Handling objectives had no supporting artefact at all. This was days of work, not months, and it moved more objectives than anything else we did.



This Project has received funding from the Digital Europe Programme under Grant Agreement No: 101190281



**Co-funded by
the European Union**



ECCC
EUROPEAN CYBERSECURITY
COMPETENCE CENTRE

REMEDIATION STEP 2



CYBERFORT
RESILIENT EUROPE

A real cybersecurity risk assessment

Intended purpose and reasonably foreseeable misuse, the operational environment, the assets protected, expected service life, and a documented scoring method. Eighteen risks with inherent and residual ratings — and an applicability determination for every Annex I requirement, because the CRA demands a justification for anything excluded.

Threats modelled, not asserted

STRIDE across the four trust boundaries that actually exist in the product, an attack-surface inventory listing every port with its authentication state, and the rationale behind each cryptographic choice. An assessor can disagree with a documented decision; they cannot evaluate an undocumented one.

A support commitment with a date on it

Five years, to 30 July 2031, which is the CRA minimum. Patch windows by severity, a 12-month end-of-support notice and an emergency zero-day runbook. The product previously declared no support period and had no version identifier for the manager at all.

Objectives moved

- ✓ Ch II Art. 13 manufacturer obligations
- ✓ Ch II Art. 25 internal processes
- ✓ Ch II Art. 26 user guidance
- ✓ Annex I 3k security updates

Why it counts

Nine of the 52 conformity questions ask about the risk assessment alone. None had an answer before this, and no amount of good engineering substitutes for the document.



This Project has received funding from the Digital Europe Programme under Grant Agreement No: 101190281



**Co-funded by
the European Union**



ECCC
EUROPEAN CYBERSECURITY
COMPETENCE CENTRE

REMEDIATION STEP 3



CYBERFORT
RESILIENT EUROPE

The manager API was entirely unauthenticated

All 22 routes on the TLS listener were open — organisation creation, agent generation, installer download with embedded private keys, alert content, and the endpoint that deletes files on endpoints. Authentication now gates the group, and fails closed rather than open if it is not configured.

We used what was already in the repository

The RS256 signing and validation code had been written and then never connected to a route. The password policy was written and never imported. Restoring the control was largely wiring — worth knowing before anyone budgets a rewrite.

Destructive actions are attributable and authorised

Every remediation command records the operator principal and the source address. The route that deletes files and kills processes is gated on an administrator or operator role — authorised, not merely reachable by anyone holding a token.

Objectives moved

- ✓ Annex I 3b protection from unauthorised access
- ✓ Annex I 2 no known exploitable vulnerabilities
- ✓ Q20, Q21, Q22 answered Yes

Why it counts

One honest limit: organisation scoping is not implemented, so a 3.4.x manager must run single-tenant. That is recorded as a deployment requirement and a risk, not presented as a control we have.



This Project has received funding from the Digital Europe Programme under Grant Agreement No: 101190281



Co-funded by
the European Union



ECCE
EUROPEAN CYBERSECURITY
COMPETENCE CENTRE

REMEDIATION STEP 4



CYBERFORT
RESILIENT EUROPE

Targets are validated by type, not just for emptiness

Before this the only check on an AI-chosen target was that the string was not empty — and it flowed to `rm -f`, `pskill` and `pfctl` running as root. Now an IP must be routable and public, a path is canonicalised and refused inside a protected prefix, and a process name is checked against a list that includes the agent itself and the host's init.

Validated twice, deliberately

The agent re-checks every target before it executes, because an endpoint must not assume the manager validated anything. Sixty-three test cases cover the rules, and response scripts run under a timeout instead of an unbounded exec.

The safe default is now the default

An absent configuration key used to mean fully automatic remediation. It now means `manual_only`, and every dispatch path honours it — including the reconnect retry that previously bypassed the gate entirely.

Objectives moved

- ✓ Annex I 1 appropriate cybersecurity
- ✓ Annex I 3a secure by default
- ✓ Annex I 3d integrity
- ✓ Annex I 3i incident impact

Why it counts

Prompt injection through log content is the attack this closes: anyone who could write a log line could previously influence which host action ran.



This Project has received funding from the Digital Europe Programme under Grant Agreement No: 101190281



**Co-funded by
the European Union**



ECCC
EUROPEAN CYBERSECURITY
COMPETENCE CENTRE

THE RE-ASSESSMENT: 70% CRA READY



CYBERFORT
RESILIENT EUROPE

70%

21 of 30 objectives

recorded in the platform, not estimated

baseline



after sprint 1



What the remaining nine objectives are.

- Eight stay partially compliant on purpose: the database is still unencrypted at rest, log content is not yet pseudonymised, blocks have no expiry, and releases are not signed.
- One stays not compliant: Chapter III. Annex III Class I requires a notified body and we have not engaged one — no amount of engineering closes that.
- No organisation scoping yet, so a 3.4.x manager must run single-tenant — a recorded deployment requirement, not a control. Agents also 401 until they hold a token.
- The tenant-wide DoC readiness widget moved 7% to 11%; it aggregates 270 objectives across nine products and needs the questionnaire completed to move further.

Subchapter	Objective Title	Requirement Description	Objective Utilities	Policies	Evidence	Compliance Status
Internal Security Processes and Controls	Article 25 (Security Measures)	Manufacturers must put in place appropriate and proportionate internal processes and measures to ensure compliance with the CRA.	Information Security Policy, Product Cybersecurity Policy, Management Review Minutes, Information Security Objectives & Plan, Confidentiality Policy, Physical Security Policy, Secure Code Policy, Encryption Policy, Risk Assessment Methodology	• Risk Management Policy	Approved	compliant
				• Software Development Lifecycle Policy	Approved	
				• Information Security Policy	Approved	
				• Information Security Objectives And Plan	Draft	
				• Product Cybersecurity Policy	Draft	
				• Encryption Policy	Review	
				• Risk Assessment Methodology	Draft	
				• Management Review Minutes	Draft	
				• Physical Security Policy	Draft	
				• Confidentiality Policy	Approved	
		Manufacturers have comprehensive obligations, including ensuring products meet	Information Security Policy, Organizational Roles, Responsibilities And Authorities, Product Registry	• Incident Management Policy	Draft	
				• Information Security Policy	Approved	

Annex I and Vulnerability Handling objectives after the sprint



This Project has received funding from the Digital Europe Programme under Grant Agreement No: 101190281



Co-funded by
the European Union



ECCC
EUROPEAN CYBERSECURITY
COMPETENCE CENTRE

PILOT OUTCOME



CYBERFORT
RESILIENT EUROPE

7%

Where we started

2 of 30 CRA objectives
compliant, 29 July

70%

Where we are now

21 of 30 compliant, 30 July
after one remediation sprint

52/52

Conformity questions answered

every answer evidenced
against a file and line

6 months

Engagement span

February to July 2026
scope, baseline, remediate, re-assess

What we did

Ran the complete CRA manufacturer workflow in CyberFort against our own product — scope, classification, SBOM, dependency and SAST scanning, risk register, VEX, the six Technical File areas, the 52-question conformity assessment, all 30 objectives, gap analysis and DoC readiness.

What we found

Four blockers that prevented a Declaration of Conformity, and nine conformity claims we could defend from code. The blockers sat in access control and in the Annex I Part II vulnerability-handling apparatus — not in the product's security engineering.

What we did about it

A remediation sprint in the second half of the engagement: 60 files, 8,261 lines. Disclosure policy, SBOM in CI, authentication restored, remediation targets validated. Re-assessed in the platform: 21 of 30 objectives compliant. Annex III Class I still requires a notified body.



This Project has received funding from the Digital Europe Programme under Grant Agreement No: 101190281



**Co-funded by
the European Union**



ECCC
EUROPEAN CYBERSECURITY
COMPETENCE CENTRE

PILOT TIMELINE



CYBERFORT
RESILIENT EUROPE

1 MONTH

Onboard

Tenant stood up and the CRA framework seeded with its chain links — 45 risks, 98 controls, 48 policies. Control and policy library imported, and the first scanner runs recorded against the product repository.

framework in place

2 MONTHS

Baseline

SEUXDR registered with its Annex III Class I classification and justification. Scans re-run against commit 00a95ad: SBOM 301 components in 23.26 s, dependency scan 34.15 s. All 30 objectives graded against code evidence; a 25-item backlog ranked.

2 of 30 • 7%

8 WEEKS

Remediation

Sprint 1 committed on branch cra/remediation-sprint-1: 60 files, 8,261 lines. Disclosure policy, SBOM in CI, nine CRA technical documents, authentication and authorisation restored, remediation targets validated, permissions tightened, credential removed.

Tier 0 closed

1 MONTH

Re-assessment

The same 30 objectives re-graded in the platform against the new evidence. No question was re-worded and no objective was removed — only the evidence changed.

21 of 30 • 70%

What moved across the engagement, measured

CRA objectives compliant

2 / 30 → 21 / 30

Security contact and CVD policy

none → published

Objectives not compliant

18 / 30 → 1 / 30

CI pipelines with security gates

0 → 2

SBOM components documented

none → 301

Declarable product version

none → 3.4.0



This Project has received funding from the Digital Europe Programme under Grant Agreement No: 101190281



Co-funded by
the European Union



ECCC
EUROPEAN CYBERSECURITY
COMPETENCE CENTRE

NEW ARTIFACTS



CYBERFORT
RESILIENT EUROPE

✓ **Software Bill of Materials**

Machine-readable, generated by Syft. The product shipped none — the closest artefact was a hand-maintained 26-entry licence list that still contained its template placeholder.

✓ **CycloneDX VEX statement set**

How we tell downstream users and authorities that a CVE in our SBOM is not exploitable in our product — the difference between an honest SBOM and an alarming one.

✓ **CRA Technical File across six areas**

SBOM management, secure SDLC evidence, security design, patch & support policy, vulnerability disclosure, dependency policy.

✓ **Risk register scoped to the product**

Five blocking risks, each linked from a scan finding to the CRA objective it violates, traceable through the compliance chain.

✓ **Conformity assessment + objective tree**

52 answers and 30 objective statuses, every one carrying an evidence description — exportable as PDF and CSV.

✓ **Gap analysis and DoC readiness record**

Objectives without evidence, objectives not compliant, objectives without linked policies — plus a live readiness score and a CE Marking Checklist.



This Project has received funding from the Digital Europe Programme under Grant Agreement No: 101190281



Co-funded by
the European Union



ECCC
EUROPEAN CYBERSECURITY
COMPETENCE CENTRE

REMEDIATION ROADMAP



CYBERFORT
RESILIENT EUROPE

Week 1

Decide and declare

cheapest, highest leverage

Notified-body route · SECURITY.md and security contact · SBOM in CI · reconcile documentation with code

Weeks 2–4

Close the access-control blockers

makes Q13 and Q20 answerable

Restore auth + RBAC · gate the remediation endpoint and record operator identity · validate targets · sign releases · encrypt at rest

Weeks 5–8

Documentation and process

closes Annex V

Risk assessment and threat model · 5-year support period · data minimisation · dependency policy · audit-trail attribution

Then

Re-run the pilot

target: >70% readiness

Re-scan, re-answer, read the new score. The compliance chain is live — repeatability, not the first score, is the platform's real value.

Target after Tier 0–I

Objectives compliant

2 / 30 → 20 / 30

Objectives not compliant

20 / 30 → 2 / 30

Answers “Yes”

2 / 52 → 34 / 52

Objectives with evidence

0 / 30 → 30 / 30

DoC readiness

7% → > 70%

3g and 3i stay “partially” on purpose.



This Project has received funding from the Digital Europe Programme under Grant Agreement No: 101190281



Co-funded by
the European Union



ECCC
EUROPEAN CYBERSECURITY
COMPETENCE CENTRE

PILOT TAKE AWAYS



CYBERFORT
RESILIENT EUROPE

Time and cost compression

One engineer, one day, to a complete and defensible position on 30 objectives and 52 questions. The same position by consulting engagement is several weeks and a five-figure fee.

Traceability, not a report

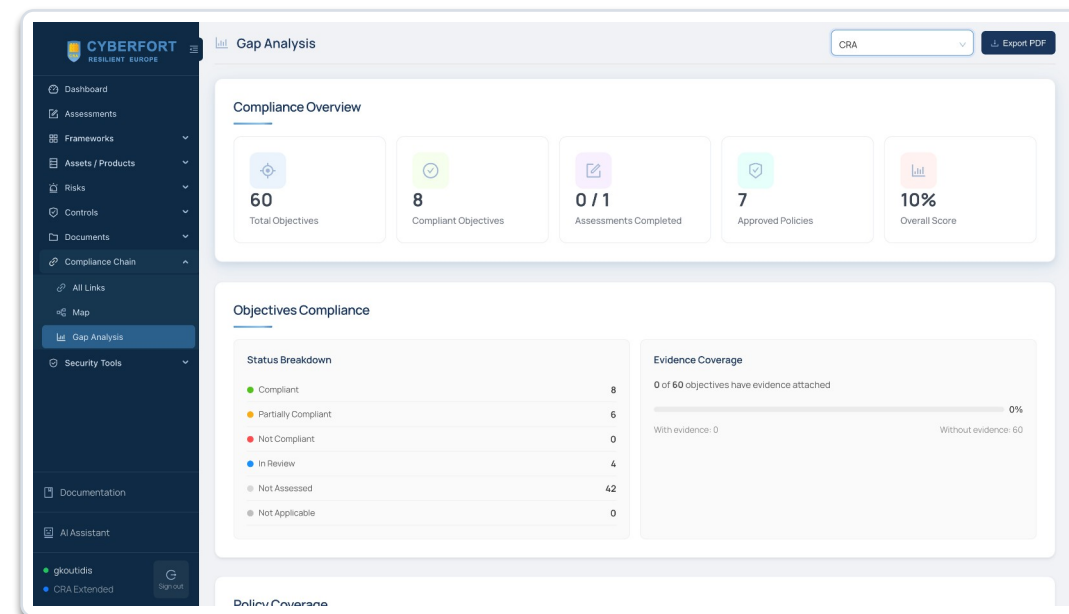
Every answer links to a finding, a risk, a control, a policy and an objective. The chain map shows where the graph has no edges — exactly what the gap analysis reports.

Repeatable after every release

A consultancy deliverable is a snapshot. This is live: re-scan, re-answer, re-read the score. That is what turns CRA compliance from a project into a process.

Honest by construction

The platform gave us 7% and four blockers on our own flagship product. A tool that flatters you is worthless in front of a notified body.



Compliance Chain → Gap Analysis, framework CRA — exportable as PDF



This Project has received funding from the Digital Europe Programme under Grant Agreement No: 101190281



Co-funded by
the European Union



ECCC
EUROPEAN CYBERSECURITY
COMPETENCE CENTRE

NEXT STEPS



CYBERFORT
RESILIENT EUROPE

1

Which build goes to market?

The assessed artefact is the authentication-stripped variant. Confirm that the CRA-conformant target is the full SEUXDR build with JWT and RBAC restored — that single decision changes two of the four blockers.

Management · August 2026

2

Approve the notified-body route

Annex III Class I removes self-assessment. We need budget and a shortlist; conformity assessment lead times are the long pole in any CE-marking plan.

Management · August 2026

3

Fund the Tier 0 sprint

SECURITY.md, SBOM in CI, dependency scanning, tagged releases and a documentation reconciliation. Small, mostly tooling, and it moves four objectives.

Engineering · Q3 2026

4

Re-run the pilot at the end of Tier I

Same asset, same framework, new score. That second number is the one to take to customers and to the CYBERFORT consortium.

Engineering · Q4 2026



This Project has received funding from the Digital Europe Programme under Grant Agreement No: 101190281



Co-funded by
the European Union



ECCC
EUROPEAN CYBERSECURITY
COMPETENCE CENTRE



THANK YOU

GEORGIOS KOUTIDIS
CLONE SYSTEMS CY, LTD.